Android Hacking 101

The Path Less Traveled

Table of contents

01

Introduction

02

YesWeHack Dojo

03

Android Basics

04

Tools, Vulns & Methodologies

05

Demo

06

Q&A

01

Introduction

Introduction

$ whoami

- seasquirr3l
- hacker / developer
- cybersecurity analyst
- loves coffee, guitars, and running

02

YesWeHack Dojo

YesWeHack Dojo

- an interactive, browser-based training and CTF (Capture The Flag) platform.
- designed for cybersecurity enthusiasts to practice bug hunting in a safe environment.

https://dojo-yeswehack.com/

YesWeHack Dojo Features

CTF Challenges

Solve monthly CTF challenges across different skill levels.

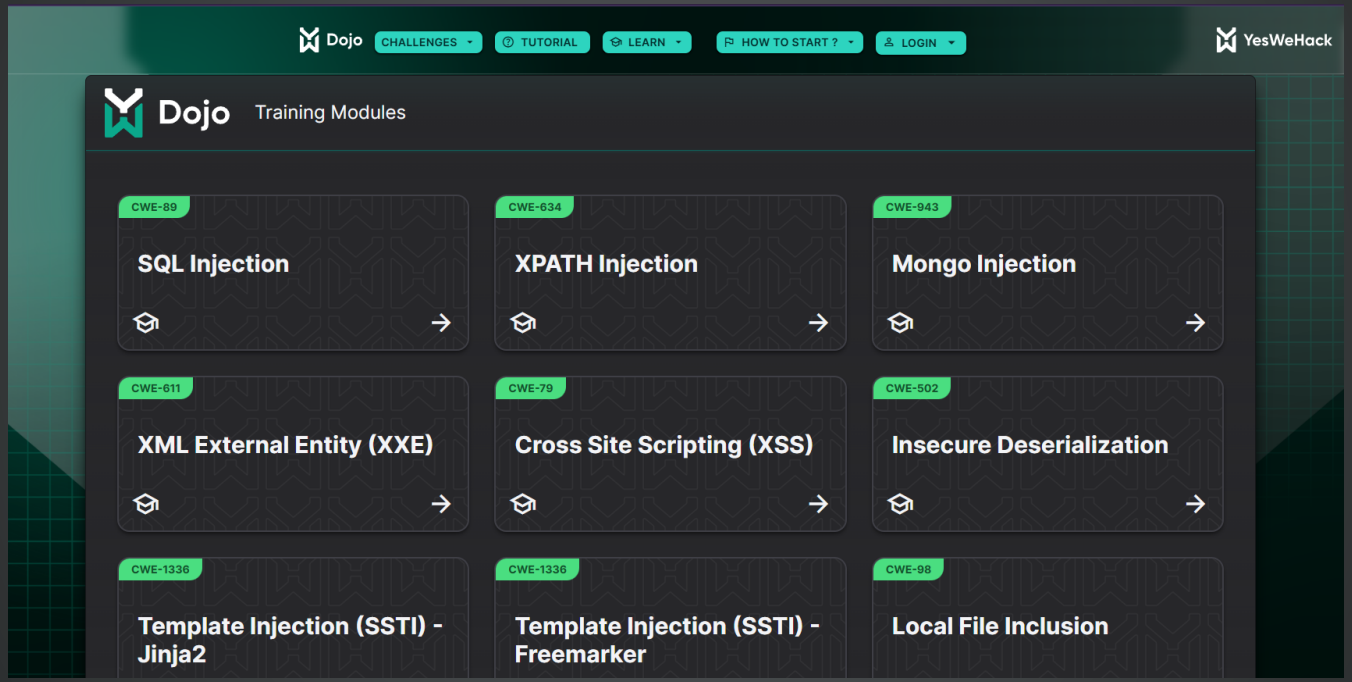
Create a challenge

Create your own CTF challenge or run code in a secure sandbox environment.

Learning modules

Practice different vulnerabilities, firewall bypasses, and modules inspired by research and real bug bounty findings.

YesWeHack Dojo Features



03

Android Basics

Android

- a widely used, open-source mobile operating system developed by Google.
- It is based on a modified Linux kernel and designed primarily for touchscreen devices like smartphones and tablets.

Android Basics

- Apps are usually installed using Google PlayStore.
- Apps can also be installed using third-party app stores, such as F-Droid.
- Apps can also be installed using APKs (Android Package Kit).

GET IT ON Google Play

GET IT ON F-Droid

Android Basics

Android Package Kit (APK)

- Installable file for Android
- It is basically a **ZIP file with code + config**
- Anyone can unpack and modify it

Android Basics

Patched/Modded APKs

- a modified version of an original Android app where someone has changed its code to bypass restrictions or add unauthorized features.

Android Basics

Why do people love modded APKs?

- Removal of ads
- Unlocking premium features for free
- Bypassing license checks
- Disabling security protections

- However, most of the time, people have no idea on what is added in the modded app.

Tools

Reverse Engineering:

- JADX, APKTool, MobSF

Proxy Tools:

- Burp Suite, Caido

Emulator:

- AVD, Genymotion

Shell and Root Access:

- ADB, Magisk

Testing Methodology

Static Analysis

- examining an Android app without running it.

We're looking at:

- Code Structure
- Resources
- Permissions
- Embedded Secrets

Testing Methodology

Dynamic Analysis

- the process of inspecting and manipulating an Android app while it is running, to observe its real behavior under real conditions.

- What does the app actually do when I press this button?
- What data is it sending over the network?
- What checks does it perform at runtime?
- What happens if I change its behavior on the fly?

Testing Methodology

OWASP MASTG (**Mobile Application Security Testing Guide**)

- a comprehensive manual for mobile app security testing and reverse engineering.
- This is similar to OWASP Top 10, but for mobile apps.

https://mas.owasp.org/MASTG/

Resources

Labs

- DIVA – Android - https://github.com/payatu/diva-android
- InjuredAndroid - https://github.com/b3nac/injuredandroid
- Insecure Bank v2 - https://github.com/dineshshetty/android-insecurebankv2

Courses

- Mobile Hacking Lab - https://www.mobilehackinglab.com/courses
- YesWeHack Dojo - https://dojo-yeswehack.com/
- Portswigger Labs - https://portswigger.net/web-security

05

Demo

06

Q&A

Thanks!

Do you have any questions?
seasquirr3l@gmail.com

CREDITS: This presentation template was created by **Slidesgo**, and includes icons by **Flaticon**, and infographics & images by **Freepik**